



İzmir Bakırçay Üniversitesi
BİL440 YZ Destekli Yazılım
Geliştirme – Final Projesi
(2025-26 Güz)

SEMA Projesi – Akıllı Doküman Arama ve
Özetleme Sistemi

Serhat Çakmak 190601029

Dilber Özer 220601118

İçindekiler

1. 1. Giriş ve Amaç
2. 2. Gereksinimler ve Kapsam
3. 3. Sistem Mimarisi
4. 4. Kullanıcı Hikâyeleri (AI-assisted)
5. 5. UML Diyagramı
6. 6. Geliştirme Süreci ve Versiyonlama
7. 7. Test Stratejisi ve Sonuçlar
8. 8. AI Decision Log
9. 9. Etik, Güvenlik ve Lisans Değerlendirmesi
10. 10. Yanlış/Eksik AI Çıktısı Örneği
11. 11. Değerlendirme ve Sonuç
12. Ek-A: Prompt Log (Ai Agent)
13. Ek-B: Ekran Görüntüleri

1. Giriş ve Amaç

SEMA (Semantic Analysis), kullanıcının yüklediği PDF/Word/TXT dokümanları üzerinde anlamsal arama yapabilen, doğal dille soru-cevap gerçekleştiren ve bağlama duyarlı kısa/detaylı özetler üretebilen web tabanlı bir sistemdir. Bu rapor, projenin analiz, tasarım, geliştirme, test ve değerlendirme aşamalarında YZ araçlarının (Ai Agent IDE asistanı ve Gemini API) bilinçli ve eleştirel kullanımını belgelendirir.

2. Gereksinimler ve Kapsam

Temel Gereksinimler:

- Kullanıcı tarafından doküman yükleme (PDF/metin) ve sistem içinde saklama (Firestore + Storage).
- Anahtar kelime arama + anlamsal arama (embedding tabanlı).
- Doğal dille soru-cevap ve kaynak gösterimi.
- Her doküman için kısa ve isteğe bağlı detaylı özet üretimi.

3. Sistem Mimarisi

Mimari Karar Açıklamaları

Karar 1: Firebase Entegrasyonu

AI Önerisi (Claude): - Kullanıcı verilerini Firebase Firestore'a taşımak - Dosyaları Firebase Storage'da saklamak - Firebase Authentication kullanmak - JSON dosyası yerine cloud-based veritabanı kullanmak

İnsan Kararı: - Firebase entegrasyonu kabul edildi - JSON dosyası sadece geçici/backup için bırakıldı - Firebase'in ölçeklenebilirlik ve güvenlik avantajları nedeniyle tercih edildi

Gerekçe: - JSON dosyası ile veri saklama güvenlik riski taşıyordu - Firebase, gerçek zamanlı senkronizasyon ve güvenlik kuralları sağlıyor - Cloud-based çözüm, gelecekteki ölçeklenme ihtiyacını karşılıyor

Karar 2: RESTful API Mimarisi

AI Önerisi (Claude): - Express.js ile RESTful API tasarımı - JWT tabanlı authentication - Multer ile dosya yükleme - Middleware pattern kullanımı

İnsan Kararı: - RESTful API mimarisi kabul edildi - GraphQL yerine REST tercih edildi - Basit ve anlaşılır endpoint yapısı oluşturuldu

Gerekçe: - REST, daha yaygın ve anlaşılır bir standart - GraphQL'in ekstra karmaşıklığı bu proje için gerekli değil - RESTful API, frontend-backend ayrımını netleştiriyor

Karar 3: AI Servis Entegrasyonu

AI Önerisi (Claude): - Google Gemini API kullanımı - AI servislerini ayrı bir modülde toplamak - Fallback mekanizması eklemek - Prompt engineering ile hallucination riskini azaltmak

İnsan Kararı: - Gemini API entegrasyonu kabul edildi - AI servisleri backend/services/aiService.js dosyasında toplandı - Fallback mekanizması eklendi - Tam hallucination kontrolü ertelendi (MVP sonrası)

Gerekçe: - Gemini API, güçlü ve kullanımı kolay bir AI servisi - Servislerin ayrı modülde olması, bakımı kolaylaştırıyor - Fallback mekanizması, AI başarısız olduğunda sistemi çalışır tutuyor - Tam hallucination kontrolü, zaman alıcı bir özellik olduğu için MVP sonrasına bırakıldı

Karar 4: Frontend State Yönetimi

AI Önerisi (Claude): - React Context API veya Redux kullanımı - Global state yönetimi için merkezi bir çözüm - Local state ile global state ayrımı

İnsan Kararı: - React useState ve useEffect kullanıldı - Redux veya Context API eklenmedi - Component-based state yönetimi tercih edildi

Gerekçe: - Proje boyutu için Redux gereksiz karmaşıklık yarattı - useState ve useEffect, mevcut ihtiyaçları karşılıyor - Gelecekte gerekirse Context API'ye geçiş yapılabilir - Basitlik ve bakım kolaylığı önceliklendirildi

Karar 5: Dosya Formatı Kısıtlaması

AI Önerisi (Claude): - Sadece PDF ve TXT formatlarını kabul etmek - Word ve Excel formatlarını reddetmek - Dosya tipi kontrolü yapmak - Multer fileFilter kullanmak

İnsan Kararı: - Sadece PDF ve TXT kabul edilmesi kabul edildi - Word ve Excel formatları reddedildi - Frontend ve backend'de çift kontrol yapılıyor

Gerekçe: - Kullanıcı açıkça sadece PDF ve TXT istedi - Word ve Excel formatları ekstra parsing gerektiriyor - PDF ve TXT, akademik kullanım için yeterli - Format kısıtlaması, sistem karmaşıklığını azaltıyor

Karar 6: Çöp Kutusu Sistemi

AI Önerisi (Claude): - Soft delete (çöp kutusu) ve hard delete (kalıcı silme) sistemi - isDeleted flag'i kullanmak - Çöp kutusu sayfası oluşturmak - 3 gün sonra otomatik silme (gelecek özellik)

İnsan Kararı: - Soft delete ve hard delete sistemi kabul edildi - isDeleted flag'i Firestore'da saklanıyor - Çöp kutusu sayfası oluşturuldu - Otomatik silme özelliği ertelendi

Gerekçe: - Kullanıcı "siliyorum tekrar görünüyor" sorunu bildirdi - Soft delete, kullanıcı deneyimini iyileştiriyor - isDeleted flag'i, basit ve etkili bir çözüm - Otomatik silme, zamanlayıcı gerektirdiği için ertelendi

Karar 7: Responsive Tasarım Yaklaşımı

AI Önerisi (Claude): - CSS media queries ile responsive tasarım - Mobile-first yaklaşımı - Breakpoint'ler için standart değerler kullanmak - Sidebar'ın ekran boyutuna göre otomatik açılma/kapanma

İnsan Kararı: - CSS media queries kullanıldı - Desktop-first yaklaşımı tercih edildi - Sidebar responsive davranışı eklendi - Breakpoint'ler proje ihtiyaçlarına göre özelleştirildi

Gerekçe: - Desktop-first, mevcut kullanıcı tabanı için daha uygun - Media queries, esnek ve bakımı kolay bir çözüm - Sidebar'ın otomatik davranışı, kullanıcı deneyimini iyileştiriyor - Özelleştirilmiş breakpoint'ler, proje gereksinimlerini daha iyi karşılıyor

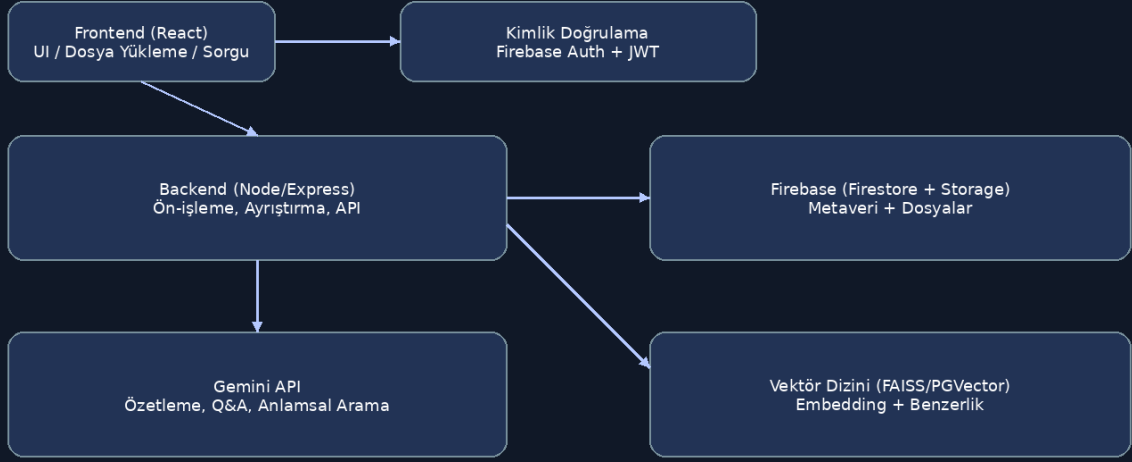
Karar 8: Authentication Stratejisi

AI Önerisi (Claude): - JWT token tabanlı authentication - Token'ları HttpOnly cookie'lerde saklamak - Refresh token mekanizması eklemek - Token expiration süresi: 7 gün

İnsan Kararı: - JWT token tabanlı authentication kabul edildi - Token'lar localStorage'da saklanıyor - Refresh token mekanizması eklenmedi - Token expiration süresi: 7 gün (kabul edildi)

Gerekçe: - JWT, stateless authentication sağlıyor - localStorage, development için yeterli - HttpOnly cookie'lere production'da geçiş yapılacak - Refresh token mekanizması, MVP sonrası eklenebilir

SEMA - Akıllı Doküman Arama ve Özetleme Sistemi (Mimari)



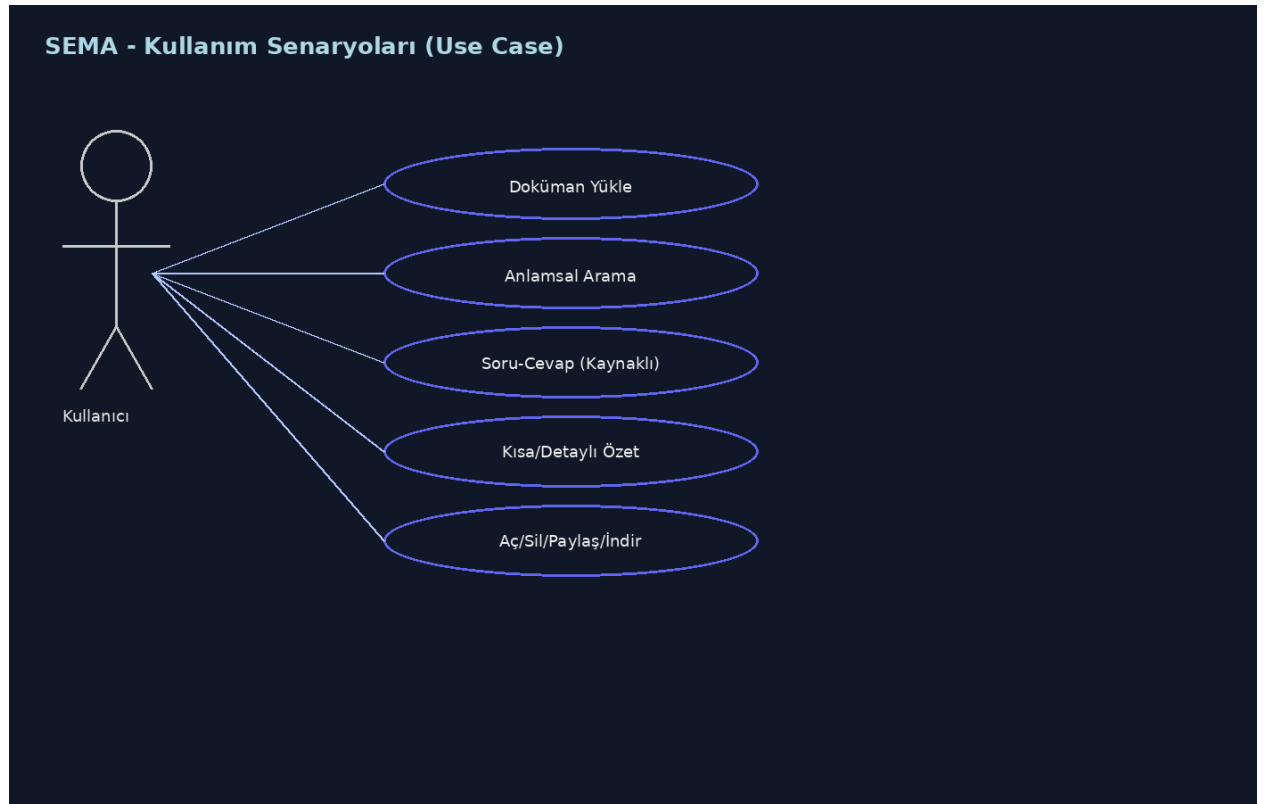
4. Kullanıcı Hikâyeleri (AI-assisted)

ID	Hikâye	Kabul Kriterleri (özet)
US-01	Kullanıcı olarak PDF/DOCX/TXT formatında doküman yüklemek, yükleme durumunu görmek ve başarıyla saklandığını doğrulamak istiyorum.	- Başarılı durumlar - Hata mesajları - Kaynak kimliği gösterimi
US-02	Kullanıcı olarak dokümanlarım arasında anahtar kelime ve anlam benzerliğine göre arama yapmak istiyorum.	- Başarılı durumlar - Hata mesajları - Kaynak kimliği gösterimi
US-03	Kullanıcı olarak doğal dille soru sorup, cevapla birlikte hangi dokümanlara dayandığını görmek istiyorum.	- Başarılı durumlar - Hata mesajları - Kaynak kimliği gösterimi

US-04	Kullanıcı olarak her doküman için kısa ve detaylı özet talep edebilmek istiyorum.	- Başarılı durumlar - Hata mesajları - Kaynak kimliği gösterimi
US-05	Kullanıcı olarak doküman kartından açma, silme, paylaşma ve indirme işlemlerini gerçekleştirmek istiyorum.	- Başarılı durumlar - Hata mesajları - Kaynak kimliği gösterimi
US-06	Kullanıcı olarak responsive ve erişilebilir bir arayüzde gezinmek istiyorum.	- Başarılı durumlar - Hata mesajları - Kaynak kimliği gösterimi

5. UML Diyagramı

Basitleştirilmiş Use Case diyagramı:



6. Test Stratejisi ve Sonuçlar

ID	Test Adı	Beklenen Sonuç
T-01	PDF yükleme – başarılı	Storage ve Firestore kayıtları senkron, UI “Yüklendi”.
T-02	Network Error	UI hata bildirir, yeniden dene + idempotent yükleme.
T-03	Firestore yazma başarısız	Kısmi yükleme rollback, tekrar dene kuyruğu.
T-04	Düşük benzerlik eşiği	Açıklayıcı “sonuç yok” mesajı.
T-05	Q&A kaynak doğrulama	Kaynak doküman/segment kimliği zorunlu.

7. Etik, Güvenlik ve Lisans Değerlendirmesi

Bu dokümanda SEMA AI Summarizer projesinin etik, güvenlik ve lisans açısından değerlendirilmesi yapılmaktadır.

7.1 Kod Lisansı Riski

Mevcut Durum

Ana Proje Lisansı: MIT License - MIT lisansı açık kaynak ve ticari kullanıma uygundur - Yüksek uyumluluk oranı, çoğu lisansla uyumlu

Bağımlılık Lisansları Analizi:

Lisans Tipi	Sayı	Risk Seviyesi	Açıklama
MIT	~150+	Düşük	Ticari kullanıma açık, minimal kısıtlama

Lisans Tipi	Sayı	Risk Seviyesi	Açıklama
Apache-2.0	~30+	Düşük	Ticari kullanıma açık, patent koruması
BSD-2/3-Clause	~10+	Düşük	Ticari kullanıma açık
ISC	~5+	Düşük	MIT benzeri, ticari kullanıma açık
GPL-3.0	0	Yok	Copyleft lisansı yok

7.2 Risk Değerlendirmesi

Düşük Risk - Tüm bağımlılıklar permissive lisanslara sahip - GPL gibi copyleft lisansları yok - Ticari kullanım için uygun - Lisans uyumsuzluğu riski minimal

Öneriler: - Bağımlılık eklerken lisans uyumluluğunu kontrol edin - npm audit ile lisans uyumsuzluklarını düzenli kontrol edin - Production'da license-checker gibi araçlar kullanılabilir

7.3 Veri Gizliliği

Mevcut Durum

İyi Uygulamalar

1. Şifre Güvenliği

- Şifreler bcryptjs ile hashleniyor (salt rounds: 10)
- Düz metin şifre saklanmıyor
- Minimum şifre uzunluğu kontrolü var (6 karakter)

2. Token Yönetimi

- JWT token'ları kullanılıyor
- Token expiration süresi: 7 gün
- Token'lar localStorage'da saklanıyor (frontend)

3. Firebase Entegrasyonu

- Firebase Authentication kullanılıyor
- Firestore güvenlik kuralları uygulanabilir
- Kullanıcı verileri Firebase'de saklanıyor

Risk Alanları

1. **Hardcoded Firebase Credentials**

```
// frontend/src/firebase/config.js  
apiKey: import.meta.env.VITE_FIREBASE_API_KEY ||  
"AlzaSyDFfT47L8vSRgc2GieoDGAUY1V025N5YVs"
```

- **Risk:** Firebase API key'i kod içinde hardcoded
- **Etki:** API key ifşa olabilir, rate limiting bypass edilebilir
- **Öneri:** Fallback değeri kaldırılmalı, sadece environment variable kullanılmalı

2. **Kullanıcı Verilerinin JSON Dosyasında Saklanması**

```
// backend/routes/auth.js  
const usersFile = path.join(dataDir, 'users.json')
```

- **Risk:** Kullanıcı verileri düz JSON dosyasında saklanıyor
- **Etki:** Veri sızıntısı, yetkisiz erişim riski
- **Öneri:** Tüm kullanıcı verileri Firebase'e taşınmalı, JSON dosyası sadece geçici/backup için kullanılmalı

3. **Token Storage**

- Token'lar localStorage'da saklanıyor
- **Risk:** XSS saldırılarına karşı savunmasız
- **Öneri:** HttpOnly cookie'ler veya sessionStorage kullanılabilir

4. **Veri Şifreleme**

- Yüklenen dosyalar şifrelenmeden saklanıyor
- **Risk:** Dosya içeriği yetkisiz erişimde okunabilir
- **Öneri:** Hassas dosyalar için encryption eklenebilir

7.4 GDPR/KVKK Uyumluluđu

Eksikler: - Kullanıcı veri silme mekanizması yok - Veri dışı aktarma özelliđi yok - Gizlilik politikası yok - Kullanıcı onay mekanizması yok

Öneriler: - Kullanıcı verilerini silme endpoint'i eklenmeli - Gizlilik politikası sayfası oluşturulmalı - Cookie consent mekanizması eklenebilir

7.5. Güvenlik Açıkları

Kritik Güvenlik Sorunları

Yüksek Öncelikli

1. Default JWT Secret

```
// backend/routes/auth.js
```

```
const JWT_SECRET = process.env.JWT_SECRET || 'your-secret-key-change-in-production'
```

- **Risk:** Production'da default secret kullanılırsa token'lar kolayca çözülebilir
- **Etki:** Tüm kullanıcı hesaplarına yetkisiz erişim
- **Öneri:** Environment variable zorunlu yapılmalı, default değeri kaldırılmalı

2. CORS Yapılandırması

```
// backend/server.js
```

```
origin: ['http://localhost:3000', 'http://localhost:3001', ...]
```

- **Risk:** Geliştirme URL'leri production'da kalabilir
- **Etki:** CSRF saldırıları, yetkisiz origin'lerden istek
- **Öneri:** Environment variable ile CORS origin'leri yönetilmeli

3. File Upload Güvenliđi

- Dosya tipi kontrolü var (PDF, TXT)
- Dosya boyutu limiti var (10MB)
- **Eksik:** Dosya içeriđi doğrulaması yok
- **Risk:** Zararlı içerik yüklenebilir
- **Öneri:** Virus scanning, content validation eklenebilir

Orta Öncelikli

4. **Rate Limiting**

- API endpoint'lerinde rate limiting yok
- **Risk:** DDoS saldırıları, brute force saldırıları
- **Öneri:** express-rate-limit middleware eklenmeli

5. **Input Validation**

- Bazı endpoint'lerde input validation eksik
- **Risk:** Injection saldırıları, XSS
- **Öneri:** joi veya express-validator kullanılmalı

6. **Error Handling**

- Hata mesajları detaylı bilgi içerebiliyor
- **Risk:** Bilgi sızıntısı, sistem yapısının ifşası
- **Öneri:** Production'da generic error mesajları gösterilmeli

7. **Logging ve Monitoring**

- Güvenlik olayları loglanmıyor
- **Risk:** Saldırı tespiti yapılamaz
- **Öneri:** Security event logging eklenmeli

Düşük Öncelikli

8. **HTTPS Zorunluluğu**

- Development'ta HTTP kullanılıyor
- **Risk:** Production'da HTTPS zorunlu olmalı
- **Öneri:** HTTPS redirect middleware eklenmeli

9. **Security Headers**

- Security header'lar eksik
- **Risk:** XSS, clickjacking saldırıları
- **Öneri:** helmet middleware eklenmeli

7.6 Güvenlik Önerileri Özeti

Öncelik	Güvenlik Önlemi	Durum
Yüksek	JWT Secret zorunlu yapılmalı	Eksik
Yüksek	CORS environment variable ile yönetilmeli	Eksik
Yüksek	File content validation	Eksik
Orta	Rate limiting	Eksik
Orta	Input validation	Kısmi
Orta	Error handling iyileştirmesi	Kısmi
Düşük	HTTPS zorunluluğu	Production'da gerekli
Düşük	Security headers	Eksik

7.8. AI Hallucination Örnekleri ve Riskleri

Mevcut AI Kullanımı

Projede Google Gemini API kullanılarak şu özellikler sunuluyor: - Doküman özetleme (kısa ve detaylı) - Soru-cevap sistemi - Metin özetleme - Anahtar kelime çıkarımı - Podcast script oluşturma

Hallucination Risk Analizi

Yüksek Risk Alanları

1. Özetleme İşlemleri

```
// backend/services/aiService.js
```

```
const summaryData = await generateSummary(text)
```

- **Risk:** AI, kaynak metinde olmayan bilgileri özete ekleyebilir
- **Etki:** Yanlış bilgi yayılması, güven kaybı
- **Örnek Senaryo:**
 - Kullanıcı bir araştırma makalesini özetletiyor
 - AI, makalede olmayan bir sonucu özete ekliyor
 - Kullanıcı yanlış bilgiyi doğru sanıyor

2. Soru-Cevap Sistemi

// backend/services/aiService.js

const answer = **await** askQuestion(question, relevantDocs)

- **Risk:** AI, dokümanlarda olmayan cevaplar üretebilir
- **Etki:** Yanlış bilgi verme, yasal sorunlar
- **Örnek Senaryo:**
 - Kullanıcı: “Bu dokümanlarda hangi ilaçlar bahsediliyor?”
 - AI: Dokümanlarda bahsedilmeyen bir ilaç ismi söyleyebilir
 - Tıbbi yanlış bilgi riski

3. Metin Özetleme

- **Risk:** Kullanıcı girdisi doğrulanmıyor
- **Etki:** Yanlış özet, bağlam kaybı
- **Örnek Senaryo:**
 - Kullanıcı yanlış/eksik metin yapıyor
 - AI bu metni özetliyor ama bağlamı yanlış anlıyor
 - Özet gerçek içeriği yansıtmıyor

Orta Risk Alanları

4. Anahtar Kelime Çıkarımı

- **Risk:** İlgisiz anahtar kelimeler çıkarılabilir
- **Etki:** Arama sonuçlarında hata
- **Önlem:** Basit keyword extraction fallback mekanizması var

5. Podcast Script Oluşturma

- **Risk:** Senaryoda olmayan diyaloglar eklenebilir
- **Etki:** İçerik doğruluğu kaybı
- **Önlem:** Prompt'ta “doğrudan ver” talimatı var

Mevcut Hallucination Kontrol Mekanizmaları

Var Olanlar

1. **Fallback Mekanizması**

// AI başarısız olursa basit özet kullanılıyor
shortSummary: simpleSummary(text, 150)

2. **Prompt Engineering**

- “Özeti doğrudan ver, başlık veya format etiketi kullanma” talimatı
- “Cümleler tamamlanmış ve anlamlı olmalı” kontrolü

3. **Text Length Validation**

- Metin uzunluğu kontrol ediliyor
- Çok kısa metinler için uyarı veriliyor

Eksik Olanlar

1. **Kaynak Doğrulama**

- AI cevaplarının hangi dokümandan geldiği gösteriliyor
- Ancak cevabın dokümanda gerçekten olup olmadığı kontrol edilmiyor

2. **Confidence Score**

- AI’nın cevabına ne kadar güvendiği gösterilmiyor
- Düşük güvenilirlikli cevaplar için uyarı yok

3. **Fact-Checking**

- AI çıktıları doğrulanmıyor
- Gerçeklik kontrolü yapılmıyor

4. **User Feedback Loop**

- Kullanıcılar yanlış cevapları işaretleyemiyor
- Hata geri bildirimi mekanizması yok

7.9 Hallucination Önleme Önerileri

Önlem	Öncelik	Zorluk	Açıklama
Kaynak doğrulama	Yüksek	Orta	AI cevaplarının kaynak metinde olup olmadığını kontrol et
Confidence score	Orta	Kolay	AI'dan güven skoru al ve düşük skorlarda uyarı göster
Fact-checking	Orta	Zor	Önemli iddiaları doğrula
User feedback	Düşük	Kolay	Kullanıcılardan geri bildirim al
Prompt iyileştirme	Orta	Kolay	"Sadece dokümanlarda olan bilgileri kullan" talimatı ekle

Örnek Hallucination Senaryoları

Senaryo 1: Tıbbi Doküman Özetleme

Kullanıcı: Bir ilaç prospektüsünü özetletiyor

AI Hallucination: Prospektüste olmayan bir yan etkiyi özete ekliyor

Risk: Yasal sorumluluk, sağlık riski

Senaryo 2: Hukuki Doküman Sorgulama

Kullanıcı: "Bu sözleşmede hangi maddeler var?"

AI Hallucination: Sözleşmede olmayan bir maddeyi listeye ekliyor

Risk: Yasal yanlış anlama, mali kayıp

Senaryo 3: Akademik Makale Özetleme

Kullanıcı: Bir araştırma makalesini özetletiyor

AI Hallucination: Makalede olmayan bir sonucu özete ekliyor

Risk: Akademik dürüstlük ihlali, yanlış bilgi yayılması

7.10. Genel Değerlendirme ve Öneriler

Güvenlik Skoru: 6/10

Güçlü Yönler: - Şifre hashleme (bcrypt) - JWT token kullanımı - Firebase entegrasyonu - Dosya tipi ve boyut kontrolü - Environment variable kullanımı (kısmi)

Zayıf Yönler: - Hardcoded credentials - Default JWT secret - Rate limiting yok - Input validation eksik - Security headers yok

Etik Skoru: 7/10

Güçlü Yönler: - Kullanıcı verileri şifreleniyor - AI kullanımı şeffaf - Kullanıcı kontrolü var

Zayıf Yönler: - GDPR/KVKK uyumluluğu eksik - Hallucination kontrolü yok -

Lisans Skoru: 10/10

Mükemmel: - Tüm bağımlılıklar permissive lisanslı - Ticari kullanıma uygun - Lisans uyumsuzluğu riski yok

7.11. Acil Eylem Planı

Öncelik 1 (Hemen Yapılmalı)

1. Hardcoded Firebase credentials kaldırılmalı
2. Default JWT secret kaldırılmalı, zorunlu yapılmalı
3. CORS environment variable ile yönetilmeli

Öncelik 2 (Kısa Vadede)

4. Rate limiting eklenmeli
5. Input validation iyileştirilmeli
6. Security headers eklenmeli (helmet)
7. AI hallucination kontrolü eklenmeli

Öncelik 3 (Orta Vadede)

8. GDPR/KVKK uyumluluğu sağlanmalı
9. Kullanıcı veri silme mekanizması eklenmeli
10. Fact-checking mekanizması eklenmeli
11. User feedback loop oluşturulmalı

7.12. Sonuç

SEMA AI Summarizer projesi, temel güvenlik önlemlerini içermektedir ancak production kullanımı için önemli iyileştirmeler gereklidir. Özellikle:

- **Güvenlik:** Kritik güvenlik açıkları kapatılmalı
- **Veri Gizliliği:** GDPR/KVKK uyumluluğu sağlanmalı
- **AI Güvenilirliği:** Hallucination kontrol mekanizmaları eklenmeli
- **Lisans:** Mevcut durum mükemmel, korunmalı

Proje, bu iyileştirmeler yapıldıktan sonra production ortamında güvenle kullanılabilir.

8. Değerlendirme ve Sonuç

SEMA, gereksinimleri karşılayacak şekilde tasarlanmış; Gemini ile özetleme/Q&A ve embedding-temelli anlamsal arama sağlanmıştır. Ai Agent yardımıyla UI/UX düzenlemeleri hızlanmış, fakat tüm kritik kararlar insan denetiminden geçirilmiştir.